

Venus Labs - Token Converter Phase 2

Security Assessment

CertiK Assessed on May 12th, 2026





CertiK Assessed on May 12th, 2026

Venus Labs - Token Converter Phase 2

The security assessment was prepared by CertiK.

Executive Summary

TYPES

Lending

ECOSYSTEM

Binance Smart Chain
(BSC)

METHODS

Manual Review, Static Analysis

LANGUAGE

Solidity

TIMELINE

Preliminary comments published on 05/06/2026

Final report published on 05/12/2026

Vulnerability Summary



14

Total Findings

12

Resolved

2

Timelock

0

Partially Resolved

0

Acknowledged

0

Declined

2 Centralization

2 Timelock

Centralization findings highlight privileged roles & functions and their capabilities, or instances where the project takes custody of users' assets.

0 Critical

Critical risks are those that impact the safe functioning of a platform and must be addressed before launch. Users should not invest in any project with outstanding critical risks.

0 Major

Major risks may include logical errors that, under specific circumstances, could result in fund losses or loss of project control.

0 Medium

Medium risks may not pose a direct risk to users' funds, but they can affect the overall functioning of a platform.

1 Minor

1 Resolved

Minor risks can be any of the above, but on a smaller scale. They generally do not compromise the overall integrity of the project, but they may be less efficient than other solutions.

11 Informational

11 Resolved

Informational errors are often recommendations to improve the style of the code or certain operations to fall within industry best practices. They usually do not affect the overall functioning of the code.

TABLE OF CONTENTS

VENUS LABS - TOKEN CONVERTER PHASE 2

Audit Summary

[Executive Summary](#)

[Vulnerability Summary](#)

[Codebase](#)

[Audit Scope](#)

[Approach & Methods](#)

Overview

[PR-158](#)

[PR-700](#)

Dependencies

[Third Party Dependencies](#)

[Recommendations](#)

Findings

[VLT-01 : Centralization Related Risks](#)

[VLT-02 : Centralized Control Of Contract Upgrade](#)

[VLT-12 : `TokenBuyback` Cap And Slippage Checks May Rely On Stale Oracle Prices](#)

[VLT-03 : Deprecated Storage Variable Doesn't Follow Conventions](#)

[VLT-04 : Shortfall Auction Path Is Functionally Disabled But Still Retained For Compatibility](#)

[VLT-05 : Potential Silent Zero-Address Fallback Issues](#)

[VLT-06 : Operator Compromise Exposes Full Accumulated Balance Of Each `TokenBuyback` Contract](#)

[VLT-07 : Missing/Incomplete NatSpec Comments](#)

[VLT-08 : `BuybackExecuted` May Report Requested Input Amount Instead Of Actual Amount](#)

[VLT-09 : Unsolicited Token Inflows Can Distort `TokenBuyback` Accounting And Event Attribution](#)

[VLT-10 : Upgrading `RiskFund` During Active `Shortfall` Auction Changes Settlement Semantics](#)

[VLT-11 : Legacy Converters Are Not Paused Before Revoking ACM Permissions During Migration](#)

[VLT-13 : `\\_enforceCapAndDetectSlippage\(\)` Uses Post-Swap Oracle State And Performs Cap Enforcement Late In Execution Flow](#)

[VLT-14 : Residual ACM Permissions Remain On Legacy Converters After Migration](#)

Appendix

Disclaimer

CODEBASE | VENUS LABS - TOKEN CONVERTER PHASE 2

Repository

Changes introduced in <https://github.com/VenusProtocol/protocol-reserve/pull/158> and <https://github.com/VenusProtocol/vips/pull/700>

Commit

<https://github.com/VenusProtocol/protocol-reserve/commit/851b9d2ac47f87e8146d9a27bd20d682ced0eaa6/>
<https://github.com/VenusProtocol/vips/commit/ab0b3a2fd40084f14e2e1c5038316a91b9045138>

Audit Scope

The file in scope is listed in the appendix.

APPROACH & METHODS

VENUS LABS - TOKEN CONVERTER PHASE 2

This audit was conducted for Venus Labs to evaluate the security and correctness of the smart contracts associated with the Venus Labs - Token Converter Phase 2 project. The assessment included a comprehensive review of the in-scope smart contracts. The audit was performed using a combination of Manual Review and Static Analysis.

The review process emphasized the following areas:

- Architecture review and threat modeling to understand systemic risks and identify design-level flaws.
- Identification of vulnerabilities through both common and edge-case attack vectors.
- Manual verification of contract logic to ensure alignment with intended design and business requirements.
- Dynamic testing to validate runtime behavior and assess execution risks.
- Assessment of code quality and maintainability, including adherence to current best practices and industry standards.

The audit resulted in findings categorized across multiple severity levels, from informational to critical. To enhance the project's security and long-term robustness, we recommend addressing the identified issues and considering the following general improvements:

- Improve code readability and maintainability by adopting a clean architectural pattern and modular design.
- Strengthen testing coverage, including unit and integration tests for key functionalities and edge cases.
- Maintain meaningful inline comments and documentations.
- Implement clear and transparent documentation for privileged roles and sensitive protocol operations.
- Regularly review and simulate contract behavior against newly emerging attack vectors.

OVERVIEW | VENUS LABS - TOKEN CONVERTER PHASE 2

This audit concerns the changes made in the in scope files outlined in the following PRs:

- [PR-158](#)
- [PR-700](#)

Note that any centralization risks present in the existing codebase before this PR were not considered in this audit and only those introduced by this PR are addressed here. We recommend all users carefully review the protocol's broader centralization risks, much of which has been discussed in previous Venus audits, which can be found here:

<https://skynet.certik.com/projects/venus>.

PR-158

This PR introduces the *TokenBuyback* architecture, which replaces the previous Token Converter system with a simpler buyback flow driven by an *ACM-authorized* operator. Rather than relying on several converter contracts, oracle-assisted conversions, and community-triggered execution, the new design allows *ProtocolShareReserve* to send funds directly to dedicated *TokenBuyback* contracts, where they can either be swapped into a configured base asset or forwarded directly to their final destination.

TokenBuyback

This contract acts as the new core buyback primitive. Each instance is configured with immutable parameters for the destination address, the base asset to be accumulated, and the *ProtocolShareReserve* address authorized to report incoming funds. It allows an ACM-authorized operator to execute swaps through an allowlisted router, while enforcing checks for balance sufficiency, router approval, expired deadlines, invalid input assets, and minimum output amounts.

RiskFundV2

This PR also updates *RiskFundV2* to align with the new buyback architecture. The contract no longer depends on the legacy converter callback flow or per-pool reserve accounting. Instead, reserve transfers for auction now rely on the contract's raw base asset balance, while the old per-pool reserve getter is preserved only for ABI compatibility and now returns zero. The token sweep logic has also been simplified to a direct balance check. Storage slots related to deprecated functionality are retained to preserve upgrade safety.

Deployment

The deployment scripts introduce new upgradeable *TokenBuyback* proxy instances for the Risk Fund, Prime, XVS Treasury, and VTreasury destinations. These proxies are deployed through `OptimizedTransparentUpgradeableProxy`, initialized with ACM, and then transferred to *NormalTimelock* ownership through a two-step process.

PR-700

This PR contains the governance-side migration file in scope, which is responsible for executing the on-chain transition from the legacy converter system to the new *TokenBuyback* architecture. In particular, the in scope `bscmainnet.ts` file comes from this PR and defines the VIP actions needed to carry out the migration on BNB Chain.

The migration includes upgrading *RiskFundV2*, accepting ownership of the newly deployed buyback proxies, allowlisting the approved router, granting ACM permissions to the designated operator, draining and disabling the legacy converter contracts, and repointing *ProtocolShareReserve* distributions to the new buyback destinations. As such, this PR serves as the operational layer that activates the contract changes introduced in *PR-158*.

DEPENDENCIES | VENUS LABS - TOKEN CONVERTER PHASE 2

Third Party Dependencies

The protocol is serving as the underlying entity to interact with third party protocols. The third parties that the contracts interact with are:

- ERC20 Tokens
- Swap Protocols
- Upgradeable proxy infrastructure
- Oracles

The scope of the audit treats third party entities as black boxes and assumes their functional correctness. However, in the real world, third parties can be compromised and this may lead to lost or stolen assets. Moreover, changes to router behavior, liquidity conditions, token mechanics, or proxy infrastructure may create unexpected operational or security risks for the protocol.

Recommendations

We recommend constantly monitoring the third parties involved to mitigate any side effects that may occur when unexpected changes are introduced, as well as vetting any third party contracts used to ensure no external calls can be made before updates to its state.

FINDINGS | VENUS LABS - TOKEN CONVERTER PHASE 2



14

Total Findings

0

Critical

2

Centralization

0

Major

0

Medium

1

Minor

11

Informational

This report has been prepared for Venus Labs to identify potential vulnerabilities and security issues within the reviewed codebase. During the course of the audit, a total of 14 issues were identified. Leveraging a combination of Manual Review & Static Analysis the following findings were uncovered:

ID	Title	Category	Severity	Status
VLT-01	Centralization Related Risks	Centralization	Centralization	● 1h Timelock
VLT-02	Centralized Control Of Contract Upgrade	Centralization	Centralization	● 48h Timelock
VLT-12	<code>TokenBuyback</code> Cap And Slippage Checks May Rely On Stale Oracle Prices	Logical Issue	Minor	● Resolved
VLT-03	Deprecated Storage Variable Doesn't Follow Conventions	Logical Issue	Informational	● Resolved
VLT-04	Shortfall Auction Path Is Functionally Disabled But Still Retained For Compatibility	Logical Issue	Informational	● Resolved
VLT-05	Potential Silent Zero-Address Fallback Issues	Logical Issue	Informational	● Resolved
VLT-06	Operator Compromise Exposes Full Accumulated Balance Of Each <code>TokenBuyback</code> Contract	Design Issue	Informational	● Resolved
VLT-07	Missing/Incomplete NatSpec Comments	Inconsistency	Informational	● Resolved
VLT-08	<code>BuybackExecuted</code> May Report Requested Input Amount Instead Of Actual Amount	Inconsistency	Informational	● Resolved
VLT-09	Unsolicited Token Inflows Can Distort <code>TokenBuyback</code> Accounting And Event Attribution	Inconsistency	Informational	● Resolved

ID	Title	Category	Severity	Status
VLT-10	Upgrading <code>RiskFund</code> During Active <code>Shortfall</code> Auction Changes Settlement Semantics	Inconsistency	Informational	● Resolved
VLT-11	Legacy Converters Are Not Paused Before Revoking ACM Permissions During Migration	Inconsistency	Informational	● Resolved
VLT-13	<code>_enforceCapAndDetectSlippage()</code> Uses Post-Swap Oracle State And Performs Cap Enforcement Late In Execution Flow	Inconsistency	Informational	● Resolved
VLT-14	Residual ACM Permissions Remain On Legacy Converters After Migration	Inconsistency	Informational	● Resolved

VLT-01 | Centralization Related Risks

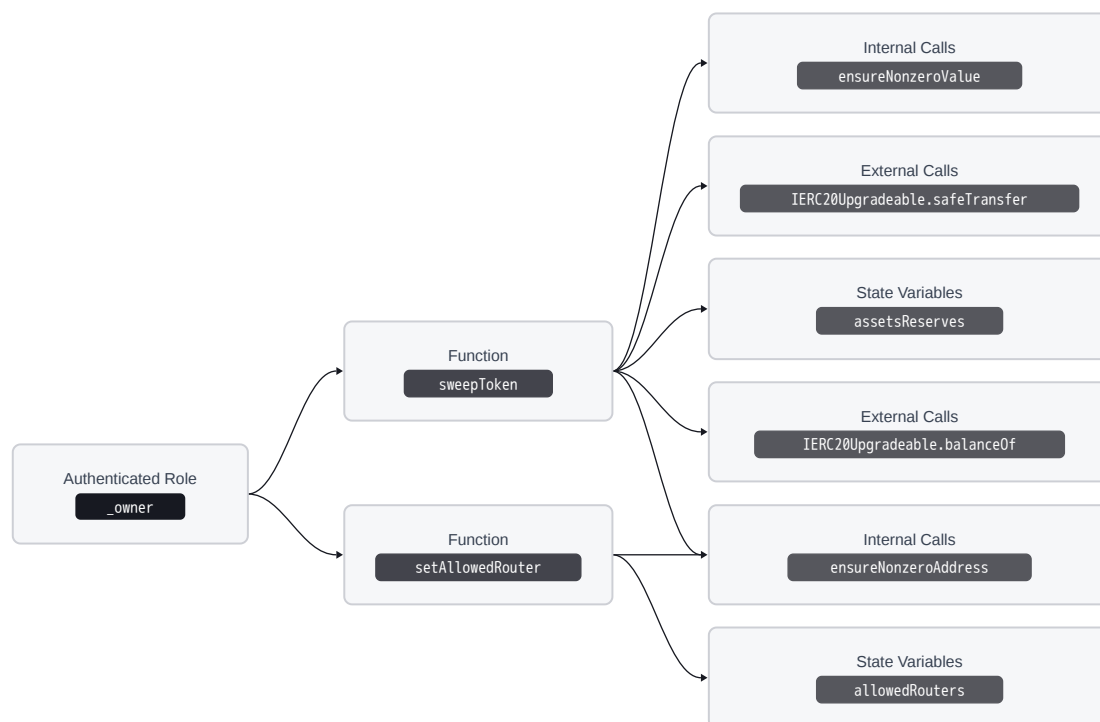
Category	Severity	Location	Status
Centralization	● Centralization	TokenBuyback.sol (Base): 162, 199, 222, 240	● 1h Timelock

Description

Note that any centralization risks present in the existing codebase before the PR's in scope of this audit were not considered. Only those added to the in-scope PRs are addressed. We recommend all users carefully review the centralization risks, much of which can be found in our previous audits, which can be found here: <https://skynet.certik.com/projects/venus>.

In the contract `TokenBuyback` the role `_owner` has authority over the functions shown in the diagram below. Any compromise to the `_owner` account may allow the hacker to take advantage of this authority and do the following:

- Sweep any token held by the contract for themselves.
- Allowlist a malicious router in the hopes it will be used for a buyback.



In the contract `PendlePTVaultAdapter`, the role `DEFAULT_ADMIN_ROLE` of the `AccessControlManager` can grant addresses the privilege to call the following functions:

- `executeBuyback()`
- `forwardBaseAsset()`

Any compromise to the `DEFAULT_ADMIN_ROLE` or accounts granted this privilege may allow the hacker to take advantage of this authority and execute swaps at bad times, use weak slippage protections, or trade large balances in a way that allows sandwich attacks or other MEV-based value extraction.

Recommendation

The risk describes the current project design and potentially makes iterations to improve in the security operation and level of decentralization, which in most cases cannot be resolved entirely at the present stage. We advise the client to carefully manage the privileged account's private key to avoid any potential risks of being hacked. In general, we strongly recommend centralized privileges or roles in the protocol be improved via a decentralized mechanism or smart-contract-based accounts with enhanced security practices, e.g., multisignature wallets. Indicatively, here are some feasible suggestions that would also mitigate the potential risk at a different level in terms of short-term, long-term and permanent:

Short Term:

Timelock and Multi sign (2/3, 3/5) combination *mitigate* by delaying the sensitive operation and avoiding a single point of key management failure.

- Time-lock with reasonable latency, e.g., 48 hours, for awareness on privileged operations;
AND
- Assignment of privileged roles to multi-signature wallets to prevent a single point of failure due to the private key compromised;
AND
- A medium/blog link for sharing the timelock contract and multi-signers addresses information with the public audience.

Long Term:

Timelock and DAO, the combination, *mitigate* by applying decentralization and transparency.

- Time-lock with reasonable latency, e.g., 48 hours, for awareness on privileged operations;
AND
- Introduction of a DAO/governance/voting module to increase transparency and user involvement.
AND
- A medium/blog link for sharing the timelock contract, multi-signers addresses, and DAO information with the public audience.

Permanent:

Renouncing the ownership or removing the function can be considered *fully resolved*.

- Renounce the ownership and never claim back the privileged roles.
OR
- Remove the risky functionality.

I Alleviation

[Venus Labs, 05/07/2026]: The ownership of all contracts will be transferred to the standard Venus Normal Timelock. ACM permissions will be assigned to specific timelocks based on the required level of control, normal, fast-track, or critical, and a guardian will be designated for critical setters. All permission assignments will be executed through a VIP and approved via Venus governance, accompanied by a community post to ensure transparency to users.

VLT-02 | Centralized Control Of Contract Upgrade

Category	Severity	Location	Status
Centralization	● Centralization	RiskFundV2.sol (Base): 17; TokenBuyback.sol (Base): 108	● 48h Timelock

Description

The proxy admin has the authority to update the implementation contracts for `RiskFundV2` and the `TokenBuyback` proxy instances.

Any compromise to the proxy admin account may allow a hacker to take advantage of this authority and change the implementation contracts which are pointed to by the proxies and therefore execute potential malicious functionality in the implementation contracts.

Recommendation

We recommend that the team make efforts to restrict access to the admin of the proxy contract. A strategy of combining a time-lock and a multi-signature ($\frac{2}{3}$, $\frac{3}{5}$) wallet can be used to prevent a single point of failure due to a private key compromise. In addition, the team should be transparent and notify the community in advance whenever they plan to migrate to a new implementation contract.

Here are some feasible short-term and long-term suggestions that would mitigate the potential risk to a different level and suggestions that would permanently fully resolve the risk.

Short Term:

A combination of a time-lock and a multi signature ($\frac{2}{3}$, $\frac{3}{5}$) wallet mitigate the risk by delaying the sensitive operation and avoiding a single point of key management failure.

- A time-lock with reasonable latency, such as 48 hours, for awareness of privileged operations;
AND
- Assignment of privileged roles to multi-signature wallets to prevent a single point of failure due to a private key compromised;
AND
- A medium/blog link for sharing the time-lock contract and multi-signers addresses information with the community.

For remediation and mitigated status, please provide the following information:

- Provide the deployed time-lock address.
- Provide the **gnosis** address with **ALL** the multi-signer addresses for the verification process.

- Provide a link to the **medium/blog** with all of the above information included.

Long Term:

A combination of a time-lock on the contract upgrade operation and a DAO for controlling the upgrade operation mitigate the contract upgrade risk by applying transparency and decentralization.

- A time-lock with reasonable latency, such as 48 hours, for community awareness of privileged operations;
AND
- Introduction of a DAO, governance, or voting module to increase decentralization, transparency, and user involvement;
AND
- A medium/blog link for sharing the time-lock contract, multi-signers addresses, and DAO information with the community.

For remediation and mitigated status, please provide the following information:

- Provide the deployed time-lock address.
- Provide the **gnosis** address with **ALL** the multi-signer addresses for the verification process.
- Provide a link to the **medium/blog** with all of the above information included.

Permanent:

Renouncing ownership of the `admin` account or removing the upgrade functionality can *fully* resolve the risk.

- Renounce the ownership and never claim back the privileged role;
OR
- Remove the risky functionality.

Note: we recommend the project team consider the long-term solution or the permanent solution. The project team shall make a decision based on the current state of their project, timeline, and project resources.

I Alleviation

[Venus Labs, 05/07/2026]: The admin of the contracts on BNB Chain (where these contracts will be deployed) will be the ProxyAdmin contract at 0x1BB765b741A5f3C2A338369DAb539385534E3343. The owner of this ProxyAdmin is the Normal Timelock contract at 0x939bD8d64c0A9583A7Dcea9933f7b21697ab6396, which is responsible for executing standard Venus Improvement Proposals (VIPs) on BNB Chain. For normal VIPs, the governance process includes:

- 24 hours of voting
- 48 hours of timelock delay before execution

Therefore, any upgrade to these contracts can only be executed through a Normal VIP, ensuring that changes go through

the Venus community governance process.

VLT-12 | TokenBuyback Cap And Slippage Checks May Rely On Stale Oracle Prices

Category	Severity	Location	Status
Logical Issue	Minor	TokenBuyback.sol (Udpate1): 371~372	Resolved

Description

`TokenBuyback._enforceCapAndDetectSlippage()` uses `ResilientOracle.getPrice(tokenIn)` and `ResilientOracle.getPrice(BASE_ASSET)` to enforce the rolling daily USD cap and to emit the `AbnormalSlippage` event. However, the function does not call `updateAssetPrice()` before reading those prices. As a result, the cap and slippage logic may operate on stale oracle values if the relevant assets have not been refreshed recently.

Recommendation

We recommend calling `updateAssetPrice()` on both assets oracle prices before performing the cap and slippage calculations.

Alleviation

[CertiK, 05/08/2026]: The client made the recommended changes resolving this finding in commit [27e27d0bcb9299fe59019ad86728c99ab5ad4e1f](#).

VLT-03 | Deprecated Storage Variable Doesn't Follow Conventions

Category	Severity	Location	Status
Logical Issue	● Informational	RiskFundStorage.sol (Base): 72	● Resolved

Description

The storage variable `riskFundConverter` was deprecated. However, it was not made private and its name was not adjusted to include a prefix indicating it is deprecated.

Recommendation

We recommend being consistent in the conventions used when deprecating storage variables.

Alleviation

[CertiK, 05/07/2026]: The client made the recommended changes resolving this finding in commit [187c1d992f6721a8dd3b3b49bf6c91dfda3bf820](#).

VLT-04 | Shortfall Auction Path Is Functionally Disabled But Still Retained For Compatibility

Category	Severity	Location	Status
Logical Issue	● Informational	RiskFundV2.sol (Base): 118~131	● Resolved

Description

`getPoolsBaseAssetReserves()` now returns `0`, which functionally disables new auction reserve seizure paths. This appears intentional for post-migration behavior, but it leaves auction-related interfaces in the contract for compatibility. Once the protocol confirms no remaining operational or integration dependency on Shortfall auction flows, governance may consider full decommission/simplification to reduce long-term maintenance and cognitive overhead.

Recommendation

We recommend pausing auction creation in the `Shortfall` contract before migration, and waiting for all active auctions to finish before making further changes. Furthermore, we recommend after confirming no remaining auction dependency, decommissioning or permanently disabling unused auction-related paths to simplify the system and reduce maintenance risk.

Alleviation

[Venus Labs, 05/07/2026]: The return of 0 is intentional and documented in the NatSpec on `getPoolsBaseAssetReserves`. The shortfall auction mechanism is used exclusively by isolated pools, and isolated pools are no longer operational on BSC. There are no ongoing or upcoming auctions, so the migration window cannot encounter an auction sized against the legacy per-pool reserve model. The ABI surface (`getPoolsBaseAssetReserves`, `transferReserveForAuction`) is retained to keep the legacy `Shortfall.sol` integration compiling without requiring an additional upgrade in the same VIP. The companion VIP will still call `Shortfall.pauseAuctions()` defensively to keep the surface closed post-upgrade. Once we confirm long-term that no integration relies on these interfaces, we can fully decommission them in a follow-up PR.

VLT-05 | Potential Silent Zero-Address Fallback Issues

Category	Severity	Location	Status
Logical Issue	● Informational	006-risk-fund-buyback.ts (Base): 17, 45; 007-prime-buyback.ts (Base): 28, 59; 008-xvs-buyback.ts (Base): 17, 45; 009-treasury-buyback.ts (Base): 32, 63	● Resolved

Description

The deployment scripts do not validate that `NormalTimeLock` exists before using it in required ownership fields. If resolution fails, the helper `getContractAddressOrNullAddress()` returns `address(0)`, which is then used both for proxy ownership configuration and for two-step ownership initiation. In the latter case, `transferOwnership(address(0))` only sets `pendingOwner` to zero and cannot be completed, leaving ownership with the deployer while emitting a misleading operational signal.

Recommendation

We recommend failing immediately if `NormalTimeLock` is unresolved. If retaining deployer ownership is intended, we recommend that this fallback is made explicit by skipping the transfer and emitting a clear log, rather than proceeding with `address(0)`.

Alleviation

[Venus Labs, 05/07/2026]: The client made the recommended changes resolving this finding in commit [871b322863d3d5c27e9cde3e171843d3a09e24f0](#).

VLT-06 | Operator Compromise Exposes Full Accumulated Balance Of Each TokenBuyback Contract

Category	Severity	Location	Status
Design Issue	● Informational	TokenBuyback.sol (Base): 162	● Resolved

Description

`TokenBuyback` contracts accumulate tokens from `ProtocolShareReserve` and rely on an ACM-authorized operator to execute swaps or forward base assets. Because the operator is not constrained by on-chain daily limits, per-asset spend caps, cooldowns, or inventory ceilings, a compromised operator could attempt to swap the entire available balance in a single transaction through an approved router. If such a swap is executed with weak execution parameters, such as an overly permissive `minAmountOut`, the trade could be exposed to severe adverse execution, including sandwiching or other MEV-based value extraction, resulting in material economic loss on the full accumulated balance. While immutable destinations and router allowlisting reduce some misuse scenarios, they do not materially reduce the amount of value exposed at the time of compromise.

Recommendation

We recommend considering the following additional design measures to limit the impact of an operator compromise.

- Introduce per-day or per-epoch swap limits so the amount exposed over a short period remains bounded even if the operator is compromised.
- As an alternative or complement to on-chain limits, require the operator to execute swaps frequently so the contract balance does not accumulate to a level where a single bad execution would cause significant loss.
- Define maximum idle-balance thresholds and trigger alerts if a buyback contract balance grows beyond expected operational levels.
- Track realized execution against expected pricing, such as DEX quotes or oracle references, and alert if abnormal slippage is observed.
- Add monitoring for unusually large swaps, stale balances, repeated failed executions, or other abnormal operator behavior.
- Forward assets that already match `BASE_ASSET` promptly, where feasible, to reduce unnecessary balance accumulation.

Alleviation

[Venus Labs, 05/07/2026]: Addressed via: <https://github.com/VenusProtocol/protocol-reserve/pull/159/changes/ad790bdceed2425109454d8014591e60bc5d3bd3>

1. Daily USD cap on executeBuyback dailyCapUsd (1e18-scaled, ACM-set, default \$30k) tracks cumulative USD value of tokenIn consumed in a rolling 24h window via ResilientOracle.getPrice. The window resets lazily; calls that would push

cumulative consumption past the cap revert with `DailyCapExceeded`. This bounds blast radius from a compromised operator regardless of router calldata or `minAmountOut`.

2. `AbnormalSlippage` event emitted when oracle-priced `usdIn - usdOut` exceeds `slippageEventUsd` (1e18-scaled, ACM-set). Event-only by design so legit swaps are not blocked during oracle drift, while off-chain monitoring gets a clear signal when realized execution diverges from expected pricing (e.g. sandwiching, MEV, attacker pool routing).
3. ACM-gated config setters `setDailyCapUsd`, `setSlippageEventUsd` so governance can tune per-instance. The other items in your recommendation list are addressed off-chain: the cron is expected to forward and execute frequently to keep idle balances low, and our monitoring stack consumes `AssetsReceived`, `BuybackExecuted`, `BaseAssetForwarded`, and `AbnormalSlippage` events for alerting on stale balances, oversized swaps, and repeated failures.

VLT-07 | Missing/Incomplete NatSpec Comments

Category	Severity	Location	Status
Inconsistency	● Informational	IRiskFund.sol (Base): 10~12, 21; TokenBuyback.sol (Base): 108, 123~125	● Resolved

Description

The NatSpec comments for the `initialize()` function in the `TokenBuyBack` contract are minimal and do not mention inherited side effects such as ownership/ACM initialization or the `NewAccessControlManager` event emitted through `__AccessControlled_init(...)`.

The interface methods for `IRiskFund` have no function-level NatSpec.

The function `updateAssetsState()` is restricted to `PROTOCOL_SHARE_RESERVE` by an explicit caller check, but the NatSpec comments do not reflect this.

Recommendation

We recommend including the NatSpec comments mention above.

Alleviation

[Venus Labs, 05/07/2026]: `TokenBuyback.updateAssetsState` already carries `@custom:access` Only callable by `PROTOCOL_SHARE_RESERVE` and `@custom:error UnauthorizedCaller` from HashDit's I07 fix [Commit feea4a5](#).

`TokenBuyback.initialize` left as-is. Existing initializers in this repo (`ProtocolShareReserve`, `XVSVaultTreasury`, `RiskFundConverter`) all use minimal `@paramonly` documentation; keeping `TokenBuyback` consistent. `IRiskFund` interface predates this PR and was not modified by it. Adding NatSpec is out of scope.

VLT-08 `BuybackExecuted` May Report Requested Input Amount Instead Of Actual Amount

Category	Severity	Location	Status
Inconsistency	● Informational	TokenBuyback.sol (Base): 186	● Resolved

Description

The function `executeBuyback()` emits the `BuybackExecuted` event using the caller-supplied `amountIn` parameter rather than the actual amount of `tokenIn` consumed by the router during execution. Although the function approves the router for `amountIn`, the contract does not verify that the router spent the full approved amount before emitting the event. As a result, the emitted value may overstate the true input consumed by the swap.

Recommendation

We recommend deriving the emitted input amount from observed token balances instead of the user-supplied parameter.

Alleviation

[CertiK, 05/07/2026]: The client made the recommended changes in commit [9f926aabc097c9549f0e097432762ddc6a85c6ce1da6f54b91d1ebc90893bc3R232](#).

VLT-09 Unsolicited Token Inflows Can Distort TokenBuyback Accounting And Event Attribution

Category	Severity	Location	Status
Inconsistency	● Informational	TokenBuyback.sol (Base): 129~134	● Resolved

Description

TokenBuyback uses assetsReserves[asset] as a watermark and derives newly received funds from the difference between the contract's current ERC20 balance and that stored watermark. Because ERC20 tokens can be transferred directly to the contract by arbitrary addresses, unsolicited inflows may be merged into the next authorized accounting update. This can cause AssetsReceived to reflect a balance delta that includes tokens not transferred through the intended ProtocolShareReserve path.

In addition, executeBuyback() and forwardBaseAsset() operate on the contract's raw token balances rather than a separately tracked PSR-only balance. As a result, tokens sent directly to the contract may not only affect later accounting updates, but may also be swapped or forwarded by an authorized operator even if they were never explicitly introduced through the intended ProtocolShareReserve flow.

Moreover, sweepToken() resynchronizes assetsReserves[] to the contract's raw post-transfer balances, which can cause some directly transferred or otherwise untracked tokens to be included in the assetsReserves mapping rather than remaining distinguishable from authenticated protocol inflows

Recommendation

If precise accounting provenance is important, we recommend separating authenticated protocol inflows from passive balance-delta accounting. One approach is to treat updateAssetsState() as acknowledging only trusted transfer flows and to handle unexpected surplus through a separate reconciliation or recovery path, rather than allowing it to be merged into normal buyback accounting. If the current design is intentional, documentation and off-chain monitoring should make clear that AssetsReceived reflects observed balance deltas rather than an authenticated source-of-funds record, and that directly transferred tokens can affect later accounting updates and may also be swapped, forwarded, or moved through administrative recovery flows.

Alleviation

[Venus Labs, 05/07/2026]: Impact is bounded grieving the donor permanently loses the donated tokens (only governance sweepToken can recover them), and the attribution bias is one-shot since assetsReserves[asset] resyncs after the next PSR call. Full donation isolation requires a coordinated change on both the inflow side

(IncomeDestination.updateAssetsState(comptroller, asset, amount) so PSR passes the exact transferred amount and the watermark increments by it rather than a balance diff) and the outflow side (decrement-by-sent rather than resync to balanceOf); since this cascades to RiskFundV2, PrimeLiquidityProvider, and VTreasury, we are deferring it for now and tightening the NatSpec on assetsReserves, updateAssetsState, and sweepToken here so the current semantics are explicit.

fix: VLT-09 0cfc8e3.

VLT-10 | Upgrading RiskFund During Active Shortfall Auction Changes Settlement Semantics

Category	Severity	Location	Status
Inconsistency	● Informational	RiskFundV2.sol (Base): 82~88	● Resolved

Description

An auction started by `Shortfall` before the `RiskFundV2` upgrade is sized using the legacy per-pool reserve model, but if it is closed after the upgrade it is settled using the new global-balance model. Specifically, `Shortfall._startAuction()` snapshots the pool's available reserve through `riskFund.getPoolsBaseAssetReserves()` and stores the result in `auction.seizedRiskFund`, while `Shortfall.closeAuction()` later settles by calling `riskFund.transferReserveForAuction()`. In the legacy implementation, this transfer uses the pool-specific reserve bucket, however in the upgraded `RiskFundV2` implementation it uses the contract's raw `convertibleBaseAsset` balance and ignores the `comptroller` for accounting purposes.

If no funds are moved and the base asset remains unchanged, an in-flight auction may still close successfully after the upgrade. However, the settlement no longer draws from the originally snapshotted pool-specific reserve and instead uses the shared global balance. This changes the accounting semantics of the auction mid-lifecycle.

In addition, if the contract's raw base-asset balance is reduced before the auction is closed, the post-upgrade `transferReserveForAuction()` call may revert due to insufficient global balance even though the auction was sized from the legacy pool-specific reserve. This can delay or block settlement of an already-started auction until balances are restored or governance intervenes. The mismatch would be more severe if `convertibleBaseAsset` were changed during the transition.

Recommendation

We recommend ensuring that no `Shortfall` auction is active when upgrading to the new `RiskFundV2` implementation.

Additionally, we recommend to avoid changing `convertibleBaseAsset` during any period in which legacy auctions could still be settled against the upgraded contract. If active-auction upgrades must remain possible, introduce an explicit compatibility path so auctions opened under the legacy per-pool reserve model continue to settle against the same accounting model until completion.

Alleviation

[Venus Labs, 05/07/2026]: Shortfall auctions are exclusively used by isolated pools, which are no longer operational on BSC no ongoing or upcoming auctions are expected, so the migration cannot encounter an in-flight auction sized under the legacy per-pool model. The companion VIP will defensively call `Shortfall.pauseAuctions()` to keep the surface closed post-upgrade, and `convertibleBaseAsset` is not changed in this PR.

VLT-11 | Legacy Converters Are Not Paused Before Revoking ACM Permissions During Migration

Category	Severity	Location	Status
Inconsistency	● Informational	bscmainnet.ts (Base): 111~112, 149~153	● Resolved

Description

The migration plan revokes ACM permissions from the legacy converters after draining balances. However, if the legacy converters are intended to be fully retired, revoking ACM access alone does not necessarily leave them in an explicitly inactive state. The legacy converters still expose public conversion functions through the shared `AbstractTokenConverter` logic, and if any residual balances or active conversion configurations remain, those paths may continue to be callable unless conversion is paused first.

Recommendation

We recommend before revoking ACM permissions from the legacy converters, calling `pauseConversion()` on each converter that is intended to be retired. This makes the shutdown explicit and reduces the risk that public conversion flows remain callable after migration. Ownership may remain with the timelock so governance can still perform future sweeps or administrative cleanup if stray assets are later received.

Alleviation

[Venus Labs, 05/07/2026]: We will add a `pauseConversion()` step on every legacy converter (RiskFundConverter, four PrimeConverters, XVSVaultConverter, WBNBBurnConverter) before the drain + ACM revoke actions, so the shared `AbstractTokenConverter` public paths are explicitly halted prior to losing the ACM-gated administrative surface. Ownership remains with NormalTimelock, so governance retains the ability to sweep stray assets later if needed.

VLT-13 | `_enforceCapAndDetectSlippage()` Uses Post-Swap Oracle State And Performs Cap Enforcement Late In Execution Flow

Category	Severity	Location	Status
Inconsistency	● Informational	TokenBuyback.sol (Udpate1): 365	● Resolved

Description

`executeBuyback()` calls `_enforceCapAndDetectSlippage()` only after the router call has completed and after `BASE_ASSET` has already been transferred to `DESTINATION`. As a result, the function values `actualAmountIn` and `amountOut` using oracle state observed after the swap, rather than prices snapshotted before execution. If the executed trade can influence the relevant oracle inputs, this weakens the quality of the cap and slippage checks as a pre-trade reference point. In addition, because the daily cap is enforced only after the swap path has already been executed, transactions that would ultimately revert due to the cap still incur the gas cost of the external router call and token-transfer path.

Recommendation

We recommend snapshotting the relevant oracle prices before the router call and using those pre-swap values for the later cap and slippage calculations.

In addition, we recommend considering splitting the current logic into two phases:

- Perform a pre-swap cap check using the snapshotted oracle price and the requested or conservatively estimated input amount, so transactions that would exceed the cap fail before the external swap call. This should be used only if the design does not need cap enforcement to be based strictly on the exact `actualAmountIn` observed after execution.
- Perform the slippage comparison after the swap, but before forwarding `BASE_ASSET` to `DESTINATION`, so all validation checks occur before the final transfer step.

Alleviation

[Venus Labs, 05/08/2026]:

1. Post-swap oracle state is intentional. ResilientOracle main feeds (Chainlink / RedStone / Pyth) are off-chain push and not affected by on-chain swaps. The pivot is a TWAP, which is manipulation-resistant within a single block, and the swap router is ACM-allowlisted with a bounded dailyCapUsd. There is no realistic path by which the buyback swap moves its own pricing inputs.
2. Pre-swap snapshotting would regress accuracy. Cap accounting deliberately uses actualAmountIn derived from observed balance deltas so fee-on-transfer / rebase tokens are measured correctly. A pre-swap snapshot forces the cap onto amountIn (intent), which mis-measures these tokens.

3. Late cap enforcement is acceptable. The function is ACM-gated to a finance-team operator that tracks consumption off-chain; cap reverts are a compromised-key backstop, not a hot path. Wasted gas on a reverting tx falls on the operator wallet, not user funds.
4. Slippage detection is event-only. It does not revert and drives no on-chain decision, so its position relative to the BASE_ASSET transfer is cosmetic. The cap check, which does revert, unwinds the transfer atomically so "BASE_ASSET already at DESTINATION" is not an observable state if validation fails.

VLT-14 | Residual ACM Permissions Remain On Legacy Converters After Migration

Category	Severity	Location	Status
Inconsistency	● Informational	bscmainnet.ts (Update2): 273~281	● Resolved

Description

The migration helper pauses the six timelock-owned legacy converters and revokes only the temporary ACM permissions granted to itself, but it does not revoke the pre-existing ACM permissions already assigned to legacy governance actors. As a result, deprecated converter contracts retain residual privileged surfaces after migration, most importantly the ability to resume conversion.

Recommendation

If governance wishes to retain a narrowly scoped emergency brake, then we recommend documenting which legacy converter permissions are intended to remain after migration and why. In addition, we recommend that

`resumeConversion()` is revoked from `Guardian 2` if the protocol does not intend a non-governance actor to retain the ability to reactivate deprecated converter paths.

Alleviation

[Venus Labs, 05/12/2026]: The residual ACM permissions are retained intentionally. The pre-existing grants on the legacy converters point to trusted governance addresses (NormalTimelock, FastTrackTimelock, CriticalTimelock), which are the same governance actors that gate every other privileged operation across the protocol. Leaving these grants intact does not expand the attack surface beyond governance itself. The migration calls `pauseConversion()` on each legacy converter before the ACM cleanup step, which puts the public conversion paths (`convertExactTokens`, `convertForExactTokens`, `convertExactTokensSupportingFeeOnTransferTokens`) into a non-callable state regardless of any residual administrative permissions. The contracts are effectively retired at the user-facing surface; governance retains only the ability to administer cleanup actions on them (sweep stuck assets, re-pause/unpause for hot-fix flows, etc.) which is the desired post-migration posture.

APPENDIX | VENUS LABS - TOKEN CONVERTER PHASE 2

Audit Scope

CertiKProject/certik-audit-projects

006-risk-fund-buyback.ts

007-prime-buyback.ts

008-xvs-buyback.ts

009-treasury-buyback.ts

IRiskFund.sol

RiskFundStorage.sol

RiskFundV2.sol

TokenBuyback.sol

bscmainnet.ts

ITokenBuyback.sol

RiskFundConverter.sol

Finding Categories

Categories	Description
Centralization	Centralization findings detail the design choices of designating privileged roles or other centralized controls over the code.
Logical Issue	Logical Issue findings indicate general implementation issues related to the program logic.
Design Issue	Design Issue findings indicate general issues at the design level beyond program logic that are not covered by other finding categories.
Inconsistency	Inconsistency findings refer to different parts of code that are not consistent or code that does not behave according to its specification.

DISCLAIMER | CERTIK

This report is subject to the terms and conditions (including without limitation, description of services, confidentiality, disclaimer and limitation of liability) set forth in the Services Agreement, or the scope of services, and terms and conditions provided to you ("Customer" or the "Company") in connection with the Agreement. This report provided in connection with the Services set forth in the Agreement shall be used by the Company only to the extent permitted under the terms and conditions set forth in the Agreement. This report may not be transmitted, disclosed, referred to or relied upon by any person for any purposes, nor may copies be delivered to any other person other than the Company, without CertiK's prior written consent in each instance.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts CertiK to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. CertiK's position is that each company and individual are responsible for their own due diligence and continuous security. CertiK's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by CertiK is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis. Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

ALL SERVICES, THE LABELS, THE ASSESSMENT REPORT, WORK PRODUCT, OR OTHER MATERIALS, OR ANY PRODUCTS OR RESULTS OF THE USE THEREOF ARE PROVIDED "AS IS" AND "AS AVAILABLE" AND WITH ALL FAULTS AND DEFECTS WITHOUT WARRANTY OF ANY KIND. TO THE MAXIMUM EXTENT PERMITTED UNDER APPLICABLE LAW, CERTIK HEREBY DISCLAIMS ALL WARRANTIES, WHETHER EXPRESS, IMPLIED, STATUTORY, OR OTHERWISE WITH RESPECT TO THE SERVICES, ASSESSMENT REPORT, OR OTHER MATERIALS. WITHOUT LIMITING THE FOREGOING, CERTIK SPECIFICALLY DISCLAIMS ALL IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, TITLE AND NON-INFRINGEMENT, AND ALL WARRANTIES ARISING FROM COURSE OF DEALING, USAGE, OR TRADE PRACTICE. WITHOUT LIMITING THE FOREGOING, CERTIK MAKES NO WARRANTY OF ANY KIND THAT THE SERVICES, THE LABELS, THE ASSESSMENT REPORT, WORK PRODUCT, OR OTHER MATERIALS, OR ANY PRODUCTS OR RESULTS OF THE USE THEREOF, WILL MEET CUSTOMER'S OR ANY OTHER PERSON'S REQUIREMENTS, ACHIEVE ANY INTENDED RESULT, BE COMPATIBLE OR WORK WITH ANY SOFTWARE, SYSTEM, OR OTHER SERVICES, OR BE SECURE, ACCURATE, COMPLETE, FREE OF HARMFUL CODE, OR ERROR-FREE. WITHOUT LIMITATION TO THE FOREGOING, CERTIK PROVIDES NO WARRANTY OR

UNDERTAKING, AND MAKES NO REPRESENTATION OF ANY KIND THAT THE SERVICE WILL MEET CUSTOMER'S REQUIREMENTS, ACHIEVE ANY INTENDED RESULTS, BE COMPATIBLE OR WORK WITH ANY OTHER SOFTWARE, APPLICATIONS, SYSTEMS OR SERVICES, OPERATE WITHOUT INTERRUPTION, MEET ANY PERFORMANCE OR RELIABILITY STANDARDS OR BE ERROR FREE OR THAT ANY ERRORS OR DEFECTS CAN OR WILL BE CORRECTED.

WITHOUT LIMITING THE FOREGOING, NEITHER CERTIK NOR ANY OF CERTIK'S AGENTS MAKES ANY REPRESENTATION OR WARRANTY OF ANY KIND, EXPRESS OR IMPLIED AS TO THE ACCURACY, RELIABILITY, OR CURRENCY OF ANY INFORMATION OR CONTENT PROVIDED THROUGH THE SERVICE. CERTIK WILL ASSUME NO LIABILITY OR RESPONSIBILITY FOR (I) ANY ERRORS, MISTAKES, OR INACCURACIES OF CONTENT AND MATERIALS OR FOR ANY LOSS OR DAMAGE OF ANY KIND INCURRED AS A RESULT OF THE USE OF ANY CONTENT, OR (II) ANY PERSONAL INJURY OR PROPERTY DAMAGE, OF ANY NATURE WHATSOEVER, RESULTING FROM CUSTOMER'S ACCESS TO OR USE OF THE SERVICES, ASSESSMENT REPORT, OR OTHER MATERIALS.

ALL THIRD-PARTY MATERIALS ARE PROVIDED "AS IS" AND ANY REPRESENTATION OR WARRANTY OF OR CONCERNING ANY THIRD-PARTY MATERIALS IS STRICTLY BETWEEN CUSTOMER AND THE THIRD-PARTY OWNER OR DISTRIBUTOR OF THE THIRD-PARTY MATERIALS.

THE SERVICES, ASSESSMENT REPORT, AND ANY OTHER MATERIALS HEREUNDER ARE SOLELY PROVIDED TO CUSTOMER AND MAY NOT BE RELIED ON BY ANY OTHER PERSON OR FOR ANY PURPOSE NOT SPECIFICALLY IDENTIFIED IN THIS AGREEMENT, NOR MAY COPIES BE DELIVERED TO, ANY OTHER PERSON WITHOUT CERTIK'S PRIOR WRITTEN CONSENT IN EACH INSTANCE.

NO THIRD PARTY OR ANYONE ACTING ON BEHALF OF ANY THEREOF, SHALL BE A THIRD PARTY OR OTHER BENEFICIARY OF SUCH SERVICES, ASSESSMENT REPORT, AND ANY ACCOMPANYING MATERIALS AND NO SUCH THIRD PARTY SHALL HAVE ANY RIGHTS OF CONTRIBUTION AGAINST CERTIK WITH RESPECT TO SUCH SERVICES, ASSESSMENT REPORT, AND ANY ACCOMPANYING MATERIALS.

THE REPRESENTATIONS AND WARRANTIES OF CERTIK CONTAINED IN THIS AGREEMENT ARE SOLELY FOR THE BENEFIT OF CUSTOMER. ACCORDINGLY, NO THIRD PARTY OR ANYONE ACTING ON BEHALF OF ANY THEREOF, SHALL BE A THIRD PARTY OR OTHER BENEFICIARY OF SUCH REPRESENTATIONS AND WARRANTIES AND NO SUCH THIRD PARTY SHALL HAVE ANY RIGHTS OF CONTRIBUTION AGAINST CERTIK WITH RESPECT TO SUCH REPRESENTATIONS OR WARRANTIES OR ANY MATTER SUBJECT TO OR RESULTING IN INDEMNIFICATION UNDER THIS AGREEMENT OR OTHERWISE.

FOR AVOIDANCE OF DOUBT, THE SERVICES, INCLUDING ANY ASSOCIATED ASSESSMENT REPORTS OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, TAX, LEGAL, REGULATORY, OR OTHER ADVICE.

Elevate Your Web3 Journey

CertiK is the largest Web3 security platform combining formal verification with audits and comprehensive security solutions.

Venus Labs - Token Converter Phase 2 Security Assessment | CertiK Assessed on May 12th, 2026 | Copyright © CertiK

